



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2025-67038 Lantronix EDS5000 Code Injection Active Exploitation

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-07-01
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CVE-2025-67038 Lantronix EDS5000 Code Injection Active Exploitation - CVE / Vulnerability Threat Intelligence Report

Published: 2026-07-01 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
 - 9.1. Detection Logic Summary
 - 9.2. Sigma / Detection Rule
 - 9.3. Hunt Query
10. Threat Hunting
 - 10.1. Hunt Hypothesis
 - 10.2. Hunt Query
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

CVE-2025-67038 Lantronix EDS5000 Code Injection Active Exploitation

1. Executive Summary

CVE-2025-67038 affects Lantronix EDS5000 serial-device servers and is listed by CISA KEV after reported exploitation. The public description points to HTTP RPC command execution during failed authentication handling, making exposed OT edge devices a high-priority containment and patch target.

Lost Boys Cyber selected this issue for the daily vulnerability priority set because public reporting indicates either active exploitation or CISA KEV-level urgency and the affected technology is likely to sit on sensitive business or operational workflows. Public details are still incomplete, so defenders should treat the report as a prioritization and hunting aid rather than proof of compromise.

2. Vulnerability Metadata

Field	Value
CVE	CVE-2025-67038
Product / Component	Lantronix EDS5000 series
Weakness	HTTP RPC command/code injection path during failed authentication logging
Severity	Critical / reported critical impact where scored
Affected Versions	EDS5000 2.1.0.0R3 per NVD/source summaries
Fixed Versions	Apply vendor remediation or remove exposed device management interfaces pending patch
Disclosure / Update Window	Public reporting reviewed for 2026-07-01; some source reporting falls in a 7-day expansion window
Exploitation Status	CISA KEV-listed; exploitation attempts reported against OT edge devices

3. Source Review & Confidence

Source	Contribution	Confidence
CISA Known Exploited Vulnerabilities Catalog	CISA added CVE-2025-67038 to KEV on June 23, 2026 based on evidence of active exploitation.	High
NVD CVE-2025-67038	NVD describes a Lantronix EDS5000 HTTP RPC flaw where shell commands may execute during failed authentication log handling.	High
Positive Technologies / PT-2026-24723	Researcher advisory describes code injection in Lantronix EDS5000 series devices.	High
Industrial Cyber coverage	Reports exploitation attempts and OT-edge exposure context for Lantronix EDS5000.	Medium

Analyst confidence is medium because vulnerability identity, affected product, and remediation priority are corroborated across primary or high-quality sources, while public exploit-path specifics, actor attribution, and victimology remain limited.

4. Vulnerability Details

The public descriptions indicate a remotely reachable management or application component flaw with a high-impact compromise path. Defenders should assume exploit attempts may target internet-facing endpoints first, then pivot into privileged application, finance, OT-edge, or management workflows depending on product placement.

5. Attack Scenarios

- Internet-exposed vulnerable service receives opportunistic exploit traffic and is used for web-shell, command execution, or application takeover.
- An attacker with network reach from a compromised VPN, supplier, or internal workstation targets the affected management/application surface.
- A scanner identifies unpatched versions and chains the access into credential theft, configuration exfiltration, or operational disruption.

6. Threat Landscape & Exploitation Status

Multiple public sources report active exploitation or KEV-level urgency. No reliable public evidence reviewed in this run ties the activity to a named actor with high confidence. Treat all internet-reachable instances as urgent until patched or isolated.

7. Affected Products and Exposure

Exposure Pattern	Why It Matters
Internet-facing vulnerable service	Highest likelihood for opportunistic exploitation and mass scanning.
Internal high-value workflow	Compromise can affect ERP, management, OT edge, or privileged operational processes.
Third-party managed deployment	Patch ownership and telemetry access may be split across vendors or integrators.
Patched and isolated deployment	Residual risk shifts to historical exploitation review and credential rotation.

8. Mitigation and Workarounds

1. Patch or upgrade affected systems using vendor-supported guidance.
2. Remove management/application endpoints from direct internet exposure where feasible.
3. Review access logs for abnormal HTTP requests, authentication anomalies, shell/script execution, and new administrative changes.
4. Rotate credentials and API keys exposed to the affected service if compromise cannot be ruled out.
5. Add temporary WAF, reverse-proxy, or network ACL controls while patching is underway.

9. Detection Engineering

9.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
Unexpected HTTP requests to affected component paths	Web, reverse proxy, WAF	Identify scanning and exploit attempts.

New process execution or shell activity by service accounts	EDR / process telemetry	Detect post-exploitation execution.
Configuration or privileged account changes	Application/admin audit logs	Detect takeover activity.

9.2. Sigma / Detection Rule

```

title: Suspicious Activity Related to CVE-2025-67038 Lantronix EDS5000 Code Injection Active Exploitation
id: cve-2025-67038-lantronix-eds5000-code-in-daily
status: experimental
description: Detects suspicious process, script, or web activity for analyst triage related to the reported item. Tune product-specific fields before production use.
logsource:
  product: windows
  category: process_creation
detection:
  selection_terms:
    CommandLine|contains:
      - 'CVE-2025-67038'
      - 'curl'
      - 'wget'
      - 'powershell'
      - 'node'
  condition: selection_terms
fields:
  - Image
  - CommandLine
  - ParentImage
  - User
falsepositives:
  - Administrative testing and vulnerability validation
level: medium

```

9.3. Hunt Query

```

DeviceNetworkEvents
| where Timestamp > ago(14d)
| where RemoteUrl has_any ("oracle", "payments", "unifi", "eds", "npm", "stealc", "clickfix", "satcom", "reservation")
| summarize count(), hosts=dcount(DeviceName) by RemoteUrl, InitiatingProcessFileName
| order by count_desc

```

10. Threat Hunting

10.1. Hunt Hypothesis

If exploitation occurred, affected hosts should show unusual inbound HTTP activity followed by process execution, configuration changes, new accounts, or outbound staging traffic.

10.2. Hunt Query

```

DeviceProcessEvents
| where Timestamp > ago(14d)
| where ProcessCommandLine has_any ("CVE-2025-67038", "curl", "wget", "powershell", "cmd.exe", "/bin/sh")
| summarize count(), firstSeen=min(Timestamp), lastSeen=max(Timestamp) by DeviceName, InitiatingProcessFileName, FileName, ProcessCommandLine
| order by lastSeen desc

```

11. MITRE ATT&CK Mapping

Technique	Name	Evidence / Rationale
-----------	------	----------------------

T1190	Exploit Public-Facing Application	Vulnerability is reachable over an application or device management surface.
T1059	Command and Scripting Interpreter	Command execution or post-exploitation scripting is a plausible follow-on for high-impact flaws.
T1505	Server Software Component	Web-shell or service-side persistence should be reviewed where exploitation is suspected.

12. Validation / Lab Testing

No exploit reproduction was performed in this automated daily run. Validation consisted of source corroboration, report QA, PDF text extraction, and detection/hunt logic review.

13. Recommended Actions Summary

Priority	Owner	Action
Critical	Vulnerability Management	Inventory affected products and patch or isolate within emergency SLA.
High	SOC	Hunt for exploit and post-exploitation telemetry across the last 14-30 days.
High	IT / OT Operations	Validate backups, remote-access paths, service owners, and third-party patch accountability.
Medium	GRC	Track compensating controls and exception owners until every affected asset is remediated.

14. References

- [1] CISA Known Exploited Vulnerabilities Catalog: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- [2] NVD CVE-2025-67038: <https://nvd.nist.gov/vuln/detail/CVE-2025-67038>
- [3] Positive Technologies / PT-2026-24723: <https://dbugs.ptsecurity.com/vulnerability/PT-2026-24723>
- [4] Industrial Cyber coverage: <https://industrialcyber.co/threats-attacks/forescout-warns-pre-disclosure-exploitation-of-lantronix-flaw-mass-openwrt-targeting-exposes-ot-edge-security-gaps/>